

Password Policy — Technical Standards

Document Control

Field	Value
Standard ID	STD-SEC-003-A
Version	1.0
Effective Date	2026-08-19
Review Date	2027-08-19
Standard Owner	CISO / IT Security Team
Approved By	CISO
Classification	Internal — Restricted Distribution
Parent Policy	POL-SEC-003 — Password Policy

1. Purpose

This document provides the specific technical parameters that implement the Password Policy (POL-SEC-003). It is maintained separately from the policy so that technical configuration values can be updated as systems, threats, and regulatory guidance evolve, without requiring re-approval of the policy itself. Any change to this standard must still be reviewed by IT Security and logged in the revision history.

2. Scope

This standard applies to the same systems in scope under the Password Policy: the core banking system, the customer portal, employee workstations, administrative systems, and the development environment. Where a system-specific value differs from the general standard (e.g., a stricter regulatory requirement), the system-specific row in the tables below governs.

3. Password Requirements by System Tier

System Tier	Min. Length (password only)	Min. Length (with MFA)	Composition Rule	Blocklist Screening	Rotation
Core Banking System (critical)	20 characters	15 characters	None enforced; length + blocklist only	Mandatory, checked against breach corpus + internal weak-password list	No forced rotation unless PCI-DSS scope requires it for this system; change on suspected compromise only
Customer Portal	15 characters	12 characters	None enforced	Mandatory	No forced rotation; change on suspected compromise
Employee Workstations	15 characters	12 characters	None enforced	Mandatory	No forced rotation; change on suspected compromise
Administrative Systems	20 characters	15 characters	None enforced	Mandatory	No forced rotation unless PAM policy schedule applies
Development Environment	15 characters	12 characters	None enforced	Mandatory	No forced rotation; change on suspected compromise

Privileged/PAM-Vaulted Accounts	20 characters (system-generated)	N/A — MFA mandatory	Randomly generated by PAM	Not applicable (system-generated, not user-chosen)	Automatic rotation per Section 6 below
---------------------------------	----------------------------------	---------------------	---------------------------	--	--

Note on PCI-DSS scope: Where a system falls within the Cardholder Data Environment (CDE) and the current PCI-DSS assessment requires periodic password rotation as a compensating or baseline control for that specific system, the stricter rotation requirement applies and must be documented in the system's control matrix, overriding the "no forced rotation" default above.

4. Account Lockout and Session Timeout

System Tier	Failed Attempt Lockout Threshold	Lockout Duration	Session Idle Timeout
Core Banking System	5 attempts	Manual unlock by IT Security only	15 minutes
Customer Portal	5 attempts	15 minutes, or verified identity reset	30 minutes
Employee Workstations	5 attempts	30 minutes or Service Desk unlock	30 minutes
Administrative Systems	3 attempts	Manual unlock by IT Security only	15 minutes
Development Environment	5 attempts	30 minutes or Service Desk unlock	30 minutes

5. Approved MFA Methods

Priority	Method	Approved For
1 (Preferred)	FIDO2/WebAuthn security key or device-bound passkey	All privileged/administrative access, core banking system, remote VPN access

2	Authenticator app (push notification or TOTP)	Standard employee access, customer portal, development environment
3 (Limited use)	SMS/voice one-time passcode	Customer portal only, where stronger methods are unavailable; not permitted for employee, administrative, or privileged access
Not Approved	Security questions / knowledge-based authentication	Not permitted as an MFA factor or sole recovery mechanism on any system

6. Privileged Access Management (PAM) Configuration

- Privileged credentials are vaulted and rotated automatically by the PAM solution immediately after each checkout/session, and on a maximum fixed schedule of every 24 hours regardless of use
- Just-in-time access sessions are limited to a maximum of 8 hours and require re-authentication with phishing-resistant MFA for renewal
- All privileged sessions are recorded (keystroke and/or screen capture) and retained for a minimum of 1 year, or longer where required by SOX or FFIEC examination requirements
- Break-glass emergency access requires dual approval (two authorized approvers), is time-boxed to 4 hours, and triggers mandatory credential rotation and a documented incident review within 24 hours of use

7. Password Hashing Standard

Parameter	Requirement
Approved Algorithms	Argon2id (preferred), bcrypt, or scrypt
Disallowed Algorithms	MD5, SHA-1, unsalted SHA-256/SHA-512, reversible encryption
Salt	Unique, cryptographically random salt per password, minimum 16 bytes

Work Factor / Cost Parameter	Reviewed annually by IT Security; set to the highest value that maintains acceptable authentication latency under current infrastructure (baseline: Argon2id memory cost $\geq$ 19 MiB, iterations $\geq$ 2, per current OWASP guidance)
Pepper	An application-level secret (pepper) stored separately from the password database, managed via the enterprise secrets management system

8. Approved Password Manager

- The enterprise-licensed password manager designated by IT Security is the only approved tool for storing SecureBank work credentials
- The tool must support enterprise SSO integration, audit logging, secure sharing (not plaintext sharing) for team-based credentials, and breach-monitoring alerts
- Personal/consumer password manager accounts must not be used to store company credentials

9. Breach and Blocklist Screening

- New and changed passwords are checked in real time against a maintained blocklist that includes: the top known-breached password corpus, context-specific terms (company name, product names, common local patterns), and sequential/keyboard patterns
- The blocklist is refreshed at least quarterly with updated breach corpus data
- Where technically feasible, active employee credentials are periodically screened against newly disclosed breach data, and affected users are required to change their password immediately upon a match

10. Revision History

Version	Date	Author	Description
1.0	2026-08-19	IT Security Team	Initial release, companion to Password Policy POL-SEC-003